

Informe de Auditoría de Seguridad Web: Guía Práctica y Teórica para el Analista de Ciberseguridad

1. Fundamentos y Metodología de la Auditoría Web

1.1 Introducción a la Auditoría de Seguridad Web

La auditoría de seguridad de aplicaciones web es un proceso sistemático y riguroso diseñado para evaluar la postura de seguridad de una aplicación, con el objetivo de identificar, medir y mitigar vulnerabilidades que puedan ser explotadas por atacantes.¹ La creciente digitalización ha posicionado a las aplicaciones web como un objetivo principal para los ciberataques, lo que hace que esta disciplina sea una de las más cruciales en el campo de la ciberseguridad. El propósito fundamental de esta labor es salvaguardar la integridad, la confidencialidad y la disponibilidad de los datos sensibles y la funcionalidad del servicio.¹

En un campo tan dinámico como la ciberseguridad, la improvisación no es una opción viable. Adoptar una metodología estructurada es indispensable para garantizar que el proceso de auditoría sea exhaustivo y reproducible. Un enfoque bien definido no solo ayuda a organizar el trabajo de un analista, sino que también facilita la documentación precisa de los hallazgos y la comunicación efectiva de los riesgos al equipo de desarrollo y a la dirección de la empresa.²

Una de las guías más influyentes en este ámbito es la provista por el **Open Web Application Security Project (OWASP)**, una organización sin ánimo de lucro dedicada a mejorar la seguridad del software.¹ OWASP ofrece una gran cantidad de recursos abiertos y actualizados, siendo el OWASP Testing Guide una referencia global esencial para la realización de pruebas de seguridad en aplicaciones web.³ La importancia de OWASP reside en su papel fundamental en la defensa contra las crecientes ciberamenazas, proporcionando

un modelo estandarizado para la seguridad preventiva y activa.¹

1.2 El Ciclo de Vida de un Pentesting Web

El pentesting, o prueba de penetración, se desarrolla a lo largo de un ciclo de vida que se puede dividir en cinco fases genéricas: Reconocimiento, Escaneo, Evaluación de Vulnerabilidades, Explotación y Reporte.² Cada fase tiene un propósito distinto y contribuye al objetivo final de simular un ataque real para descubrir y evaluar debilidades.²

- **Reconocimiento (Reconnaissance):** En esta fase inicial, el objetivo es recopilar la mayor cantidad de información posible sobre el sistema objetivo, incluyendo su infraestructura de red, sistemas operativos, aplicaciones y cuentas de usuario.⁴ Se busca obtener un panorama completo para planificar una estrategia de ataque efectiva.⁴
- **Escaneo (Scanning):** A continuación, se utilizan herramientas para identificar puertos abiertos, servicios en ejecución y otras características de la red del objetivo, creando un "mapa" del entorno.²
- **Evaluación de Vulnerabilidades (Vulnerability Assessment):** Con la información recopilada, se identifican las vulnerabilidades potenciales y se determina si pueden ser explotadas.²
- **Explotación (Exploitation):** Esta es la fase donde el analista intenta activamente acceder al sistema, utilizando herramientas para capitalizar las vulnerabilidades identificadas y demostrar su impacto.²
- **Reporte (Reporting):** El proceso culmina con un informe detallado que documenta las vulnerabilidades, su impacto y las recomendaciones para su corrección.²

La metodología de OWASP, descrita en su Testing Guide, proporciona un enfoque más granular que se alinea perfectamente con estas fases genéricas. Por ejemplo, la fase de Information Gathering de OWASP es un subconjunto directo del Reconnaissance genérico, mientras que las pruebas de Identity Management o Authorization son el corazón de la Vulnerability Assessment y Exploitation.³ Comprender esta correspondencia es fundamental para un analista, ya que le permite ver la auditoría como un proceso cohesivo, donde OWASP proporciona el "cómo" y el "qué probar" dentro de cada "fase" del pentesting. Esta relación se ilustra a continuación en la Tabla 1.

Fase Genérica del Pentesting	Etapas de la OWASP Testing Guide
Reconocimiento	Information Gathering

Escaneo y Evaluación	Configuration and Deployment Management Testing Identity Management Testing Authentication Testing Authorization Testing Session Management Testing Input Validation Testing
Explotación	Business Logic Testing Client-side Testing Web Services Testing
Reporte	Reporting (documentación de los hallazgos)

Además de la guía de pruebas, el **OWASP Top 10** es un barómetro dinámico de las amenazas más peligrosas y frecuentes. Esta lista, que se actualiza periódicamente para reflejar las últimas tendencias en ciberseguridad, trasciende la simple enumeración de fallas.¹ Su evolución, por ejemplo, al consolidar vulnerabilidades específicas como IDOR bajo la categoría más amplia de Broken Access Control ⁶, demuestra una maduración en la comprensión de la seguridad, pasando de fallas puntuales a categorías de riesgo más holísticas. Esto subraya que la profesión de analista no consiste únicamente en conocer las vulnerabilidades, sino también en comprender la dinámica en constante cambio del panorama de amenazas y adaptarse continuamente al mismo.

2. Recopilación de Información (Fase de Reconocimiento)

2.1 Recolección Activa vs. Pasiva

La fase de reconocimiento, a menudo denominada **footprinting**, es el proceso de recopilar la mayor cantidad de datos sobre un objetivo para planificar un ataque cibernético dirigido.⁵ En un contexto ético, este proceso es la base de un pentest bien ejecutado. Existen dos enfoques principales para esta recopilación de inteligencia: el pasivo y el activo.²

El **reconocimiento pasivo** se lleva a cabo sin interactuar directamente con el sistema

objetivo.⁵ Se obtiene información de fuentes disponibles públicamente, lo que lo convierte en un método "sigiloso" que no activa sistemas de detección de intrusiones.⁸ Este enfoque es el primer paso estratégico para un analista profesional, ya que permite obtener un panorama general de los activos y posibles puntos de entrada sin alertar al objetivo de la prueba.²

En contraste, el **reconocimiento activo** implica una interacción directa con el sistema objetivo para obtener información.⁵ Este método es más "ruidoso" y puede ser detectado, por lo que se utiliza de manera selectiva una vez que el analista tiene un conocimiento básico del objetivo.⁴ La elección del método es una decisión estratégica: un analista siempre comenzará con las técnicas menos intrusivas y solo después de obtener un panorama general pasará a la interacción directa, minimizando así el riesgo de detección en las etapas iniciales de la auditoría.

2.2 Técnicas y Herramientas para el Reconocimiento Pasivo (OSINT)

Las técnicas de inteligencia de fuentes abiertas (OSINT) son la columna vertebral del reconocimiento pasivo.

- **Google Dorking:** Consiste en utilizar operadores de búsqueda avanzados para encontrar información que los administradores han dejado expuesta involuntariamente.² Esto puede incluir archivos sensibles, directorios indexables o datos de configuración.
- **WHOIS y DNS:** **WHOIS** es un protocolo para obtener información pública sobre los registros de un dominio, como los datos de contacto del propietario o del registrador.⁸ El hecho de que esta información esté oculta es un indicio de la madurez de seguridad del objetivo. Por su parte, **DNS Recon** es una herramienta que se utiliza para enumerar registros DNS de un dominio, revelando subdominios y otros detalles de la infraestructura.⁹
- **Motores de Búsqueda Especializados (Shodan, Censys):** Un analista profesional comprende que la superficie de ataque de una organización va mucho más allá de su sitio web principal. Herramientas como **Shodan**, a menudo llamado "el Google de los hackers", indexan dispositivos conectados a Internet en lugar de páginas web, lo que permite encontrar servidores web con puertos abiertos, cámaras de seguridad expuestas o servicios con versiones vulnerables.²
Censys es un complemento que se enfoca en metadatos TLS y HTTPS, lo que permite auditar certificados y configuraciones de cifrado débiles.¹²
- **Herramientas de Análisis de Inteligencia Visual: Maltego** es una herramienta que visualiza las relaciones entre personas, dominios, direcciones IP y correos electrónicos, permitiendo al analista mapear la infraestructura y las conexiones de una organización de forma gráfica y detallada.¹¹ Esta capacidad para ver las interconexiones en un grafo

facilita la identificación de vínculos y estructuras que serían difíciles de detectar manualmente.

2.3 Técnicas y Herramientas para el Reconocimiento Activo

Una vez que se tiene un panorama general a partir de fuentes pasivas, el reconocimiento activo se utiliza para obtener información más precisa y detallada.

- **Escaneo de Puertos y Servicios (Nmap):** Nmap (Network Mapper) es una herramienta robusta utilizada para sondear un objetivo y descubrir qué puertos están abiertos, qué servicios se están ejecutando y qué versiones de software están expuestas.²
- **Enumeración de Tecnologías:** Extensiones de navegador como Wappalyzer o herramientas como WhatWeb permiten identificar rápidamente las tecnologías subyacentes de una aplicación web, como el sistema de gestión de contenidos (CMS), los frameworks y las bibliotecas utilizadas.³

A continuación se presenta una tabla que resume las herramientas clave de esta fase, diferenciando entre las técnicas pasivas y activas.

Herramienta	Tipo de Reconocimiento	Propósito	Ejemplo de Uso
WHOIS	Pasivo	Obtener información de registro de dominios.	whois example.com ³
Google Dorking	Pasivo	Encontrar información sensible en motores de búsqueda.	site:example.com filetype:pdf
Shodan	Pasivo	Buscar dispositivos y servicios conectados a Internet.	hostname:example.com

Maltego	Pasivo	Visualizar relaciones entre entidades (dominios, IPs, personas).	Mapear la infraestructura de una empresa.
Wappalyzer	Pasivo	Identificar tecnologías de una web.	Extensión del navegador para enumerar CMS.
Nmap	Activo	Escanear puertos y servicios.	<code>nmap -sC -sV example.com</code> ³
TheHarvester	Pasivo	Recopilar correos y subdominios de fuentes públicas.	<code>theharvester -d example.com -b google</code> ¹¹

3. El Proxy como Eje Central de la Auditoría

3.1 Concepto y Funcionamiento de un Proxy Web

En el contexto de la auditoría de seguridad, un proxy web es una herramienta que actúa como intermediario entre un navegador y un servidor de destino.¹³ Cuando un analista configura su navegador para utilizar un proxy, todas las solicitudes (del navegador al servidor) y las respuestas (del servidor al navegador) se canalizan a través de esta herramienta.¹⁴ Esto le otorga al analista una visibilidad y un control sin precedentes sobre la comunicación web, permitiéndole interceptar, inspeccionar y modificar el tráfico en tiempo real.¹⁴ Los proxies son una capa valiosa para la seguridad y la privacidad, ya que pueden ocultar la dirección IP, filtrar contenido o actuar como un firewall.¹³

3.2 Burp Suite: La Herramienta del Analista

Burp Suite se ha consolidado como la plataforma líder para las pruebas de seguridad de aplicaciones web.¹⁵ Desarrollada por PortSwigger, ofrece un conjunto integral de herramientas que trabajan en conjunto para facilitar todo el proceso de auditoría.¹⁵ Existen dos versiones principales:

- **Burp Suite Community Edition:** La versión gratuita, ideal para estudiantes y principiantes, aunque con funcionalidades limitadas.¹⁵
- **Burp Suite Professional Edition:** La versión de pago, que ofrece un conjunto completo de herramientas avanzadas para profesionales que realizan pentests de forma regular e intensiva.¹⁵

Para comenzar a utilizar Burp, es esencial configurarlo como proxy en el navegador. Esto se hace ajustando la configuración de red del navegador para que enrute todo el tráfico a la dirección 127.0.0.1 (localhost) y al puerto 8080, donde Burp Suite escucha por defecto.¹⁸ La extensión de navegador FoxyProxy es una herramienta popular que simplifica este proceso, permitiendo al analista activar y desactivar la configuración del proxy con un solo clic, sin tener que modificar la configuración manualmente en cada momento.¹⁸

3.3 Funcionalidades Clave de Burp Suite para la Auditoría

La verdadera potencia de Burp Suite reside en la sinergia de sus herramientas. Un analista experto no utiliza cada componente de forma aislada, sino que los integra en un flujo de trabajo lógico para optimizar el proceso de auditoría.

- **Burp Proxy:** Es el corazón de Burp Suite, el componente que intercepta todo el tráfico HTTP/HTTPS entre el navegador y el servidor.¹⁵ La pestaña HTTP history almacena un registro detallado de todas las solicitudes y respuestas, permitiendo al analista analizar el comportamiento de la aplicación y detectar puntos de interés para una inspección más profunda.²⁰
- **Burp Repeater:** Esta herramienta está diseñada para enviar una petición de forma manual una y otra vez, modificando sus parámetros para estudiar la respuesta del servidor sin tener que interceptarla cada vez.²¹ Un analista puede, por ejemplo, identificar una petición interesante en el Proxy y enviarla al Repeater para probar diferentes valores en un parámetro, buscando vulnerabilidades de inyección o fallas en el control de acceso.²²
- **Burp Intruder:** Mientras que Repeater es para pruebas manuales, Intruder es la herramienta para ataques automatizados y personalizados.¹⁶ Permite a un analista realizar

brute-forcing y fuzzing para descubrir vulnerabilidades de manera más eficiente.¹⁶

Intruder ofrece varios tipos de ataque:

- **Sniper:** Inyecta cada payload de una lista en una posición de parámetro a la vez.²⁴
- **Battering ram:** Inyecta el mismo payload en todas las posiciones definidas simultáneamente.²⁴
- **Pitchfork:** Utiliza diferentes listas de payloads, inyectando un payload de cada lista de forma simultánea en cada posición.²⁴
- **Cluster bomb:** Prueba todas las combinaciones posibles de payloads en cada posición, siendo ideal para ataques como la fuerza bruta de nombres de usuario y contraseñas.²⁴
- **Burp Decoder:** Esta herramienta es crucial para la investigación de datos ofuscados.¹⁷ Permite al analista codificar y decodificar información en varios formatos, como URL, HTML, Base64, ASCII Hex, Hex, Octal y Binario.¹⁷
- **Burp Scanner:** Disponible en la versión profesional, es un escáner de vulnerabilidades automatizado que complementa el análisis manual.¹⁶ Puede realizar escaneos completos y auditorías de vulnerabilidades, lo que permite al analista concentrarse en los hallazgos más críticos y complejos.¹⁶

El flujo de trabajo es el siguiente: se utiliza el Proxy para descubrir una petición interesante, se envía al Repeater para probarla manualmente, si se confirma una posible vulnerabilidad, se utiliza el Intruder para automatizar un ataque de fuerza bruta o fuzzing, y si en el proceso se encuentra información ofuscada, se utiliza el Decoder para analizar los datos.¹⁷ Esta comprensión del flujo de trabajo es lo que transforma a un usuario de la herramienta en un verdadero profesional de la auditoría.

4. Análisis y Explotación de Vulnerabilidades Específicas

4.1 Fallos en el Control de Acceso

Vulnerabilidad IDOR (Insecure Direct Object Reference)

IDOR es una manifestación de la categoría de vulnerabilidad Broken Access Control (Control de Acceso Roto).⁶ Ocurre cuando un atacante puede acceder a objetos internos (como perfiles de usuario, documentos o registros) al manipular una referencia directa que está expuesta en una URL o en los parámetros de una solicitud.⁶ Por ejemplo, en una URL como `www.dominio.com/ver_perfil?id=12345`, un atacante podría simplemente cambiar el valor del parámetro a 12346 para intentar ver el perfil de otro usuario.⁶

La detección de esta vulnerabilidad es un proceso manual y lógico. El analista puede utilizar el Burp Repeater para enviar la petición original y luego modificar el valor de la referencia a un número adivinado. Una respuesta que revele información de otro usuario o un error inusual es una clara señal de una falla de IDOR.⁶ Su explotación es simple, pero sus consecuencias pueden ser devastadoras, ya que puede exponer información personal, financiera o médica sensible.⁶

Vulnerabilidad Directory Traversal (Path Traversal)

El Directory Traversal es una falla que permite a los atacantes acceder a archivos y directorios no deseados en el sistema de archivos del servidor, fuera de la ruta de acceso prevista de la aplicación.²⁷ La vulnerabilidad surge cuando la aplicación no valida adecuadamente la entrada del usuario utilizada para construir rutas de archivo.

La explotación típica de esta vulnerabilidad implica el uso de la secuencia `../` (o su versión codificada `%2e%2e/` para evadir filtros).²⁸ Un atacante puede insertar esta secuencia repetidamente en un parámetro de URL para navegar hacia arriba en la estructura de directorios del servidor, con el objetivo de leer archivos sensibles como `/etc/passwd`.²⁷ Un analista puede utilizar el Burp Repeater para probar este tipo de inyección en cualquier parámetro de archivo o ruta que encuentre en la aplicación. La explotación exitosa puede llevar desde la lectura de información sensible hasta la ejecución de código arbitrario y el compromiso total del servidor web.²⁷

La causa raíz de las vulnerabilidades IDOR y Directory Traversal es una falta de implementación correcta del control de acceso.⁷ Ambas se derivan de un fallo lógico, no necesariamente de una inyección de código como tal, donde el servidor no verifica que el usuario tiene los permisos adecuados para acceder a un recurso específico. La comprensión de este principio unificador es vital para un analista, ya que le permite pensar en categorías de riesgo más amplias y no solo en técnicas de ataque individuales.

4.2 Fallos en la Validación de Entrada (Input Validation)

La validación de entrada es un proceso crucial de seguridad que garantiza que los datos proporcionados por el usuario sean seguros y cumplan con los criterios esperados antes de ser procesados.³⁰ Se debe recordar que cualquier validación realizada en el lado del cliente (como con JavaScript) es insuficiente y puede ser fácilmente eludida con un proxy web como Burp Suite, por lo que la validación en el servidor es la única defensa confiable.³⁰

Inyección SQL (SQLi)

La inyección SQL es una de las vulnerabilidades más críticas y conocidas. Ocurre cuando un atacante inserta sentencias SQL maliciosas en los campos de entrada de una aplicación, interfiriendo con las consultas que la aplicación realiza a su base de datos.⁷ Esto puede resultar en el robo, modificación o eliminación de datos, e incluso en la escalada de privilegios.³²

Existen varios tipos de ataques de inyección SQL:

- **Basado en Errores (Error-based):** El atacante explota los mensajes de error de la base de datos para obtener información sobre su estructura o contenido.³³
- **Ciega (Blind SQLi):** Ocurre cuando la aplicación no devuelve los resultados de la consulta ni mensajes de error. En este caso, el atacante debe inferir información bit a bit, utilizando respuestas booleanas (verdadero/falso) o time delays (retrasos de tiempo) para determinar la veracidad de una condición.³²

Para detectar y explotar esta vulnerabilidad, un analista puede utilizar el Burp Proxy para identificar un punto de entrada de datos, como un campo de búsqueda, y luego enviarlo a una herramienta automatizada como sqlmap. Esta herramienta puede probar sistemáticamente diferentes payloads de inyección para determinar la vulnerabilidad y extraer la información deseada.³²

Cross-Site Scripting (XSS)

El XSS es un ataque de inyección de código del lado del cliente donde scripts maliciosos

(generalmente JavaScript) se inyectan en una página web.⁷ El objetivo es que estos scripts se ejecuten en el navegador de otros usuarios, lo que puede llevar al robo de cookies de sesión, datos personales o credenciales.⁷

Existen tres tipos principales de XSS:

- **Reflejado:** El script inyectado se refleja inmediatamente en la respuesta de la aplicación, a menudo a través de un parámetro de URL.⁷
- **Almacenado:** El script malicioso se almacena de forma persistente en la base de datos de la aplicación (por ejemplo, en un comentario o un perfil de usuario) y se ejecuta cada vez que otro usuario accede a la página.⁷
- **Basado en DOM (DOM-based):** El ataque ocurre en el lado del cliente, donde la vulnerabilidad reside en el código JavaScript que manipula el Modelo de Objetos del Documento (DOM) de la página.⁷

Un analista puede probar XSS utilizando Burp Suite siguiendo un proceso sencillo ²⁰:

1. Se utiliza el Burp Proxy para identificar una entrada de datos que es reflejada en la respuesta del servidor.
2. Se envía la petición al Repeater.
3. Se inyecta un payload de prueba, como `<script>alert(1)</script>`, en el campo de entrada.
4. Finalmente, se ve la respuesta en un navegador para verificar si la alerta se ejecuta, lo que confirmaría la vulnerabilidad.³⁴

Inyección de Comandos (Command Injection)

La inyección de comandos permite a un atacante ejecutar comandos arbitrarios en el sistema operativo del servidor.²⁹ La vulnerabilidad surge cuando la aplicación no valida las entradas del usuario que se pasan a funciones del sistema (

`system()`, `exec()`).³⁵ Un ejemplo claro de esta falla es cuando un desarrollador utiliza una entrada de usuario para un comando, y un atacante puede añadir el payload

`rm -rf /` para borrar recursivamente el sistema de archivos del servidor.³⁵

Inclusión de Archivos (File Inclusion - LFI/RFI)

Esta vulnerabilidad ocurre cuando una aplicación web incluye un archivo en su respuesta sin

validar la entrada del usuario.³⁷ El atacante puede manipular el parámetro de entrada para especificar un archivo que no estaba destinado a ser incluido.²⁹ La gravedad de esta vulnerabilidad depende de si se trata de una inclusión local o remota:

- **LFI (Local File Inclusion):** El atacante solo puede incluir archivos ya presentes en el servidor, lo que puede llevar a la divulgación de información sensible.³⁷
- **RFI (Remote File Inclusion):** El atacante puede incluir y ejecutar un archivo desde un servidor remoto que controla, lo que es mucho más peligroso y puede llevar a la ejecución de código arbitrario.³⁷

4.3 Fallos en la Autenticación

Ataques de Fuerza Bruta

Los ataques de fuerza bruta son un método antiguo pero persistente que consiste en intentar adivinar credenciales de acceso probando sistemáticamente todas las combinaciones posibles.³⁹ El uso de botnets, que pueden realizar miles de intentos de inicio de sesión por hora, ha acelerado significativamente este proceso.⁴⁰

Existen varios tipos de ataques de fuerza bruta:

- **Ataques de Diccionario:** Utilizan una lista de contraseñas y nombres de usuario comunes.³⁹
- **Ataques Híbridos:** Combinan palabras de un diccionario con caracteres especiales, números y años para adivinar contraseñas como "SanDiego123".³⁹
- **Credential Stuffing:** Reutilizan credenciales robadas de una filtración de datos previa para intentar acceder a otras plataformas, aprovechando el mal hábito de los usuarios de reutilizar contraseñas.³⁹

El credential stuffing es la culminación de un problema de seguridad más amplio que trasciende la aplicación que se está auditando. Subraya una realidad crucial: la superficie de riesgo de una organización se extiende hasta los hábitos de seguridad de sus usuarios y las fallas de seguridad de terceros.

La detección y prevención de estos ataques es crítica. Las defensas clave incluyen la limitación de la tasa de intentos (rate limiting), los bloqueos de cuenta temporales tras múltiples intentos fallidos y, la medida más efectiva, la implementación de la autenticación de

doble factor (2FA/MFA).⁴⁰

5. Configuraciones de Seguridad y Debilidades Criptográficas

5.1 Métodos HTTP y Cabeceras de Seguridad

Los métodos HTTP, como GET y POST, son fundamentales en la comunicación web.⁴¹ Mientras que GET se utiliza para solicitar recursos, POST está diseñado para enviar datos al servidor, y su uso adecuado es una práctica de seguridad básica.²⁹

Más allá de los métodos, las cabeceras de seguridad HTTP son una capa de defensa que mitiga ataques comunes a nivel de navegador.²⁹

- **X-Frame-Options:** Esta cabecera es crucial para prevenir ataques de clickjacking.⁴² Con valores como DENY o SAMEORIGIN, le indica al navegador si la página puede ser incrustada en un frame o iframe en otro sitio, protegiendo al usuario de hacer clic en elementos maliciosos invisibles.⁴²
- **X-Content-Type-Options:** Con el valor nosniff, esta cabecera previene los ataques de "MIME type sniffing", donde el navegador intenta adivinar el tipo de contenido de una página si no está definido.⁴² Esto evita que un archivo inofensivo (como una imagen) sea interpretado como un archivo ejecutable (como HTML), lo que podría permitir una inyección XSS.⁴²
- **Content-Security-Policy (CSP):** Considerada la sucesora de X-Frame-Options, CSP es una cabecera más poderosa que permite a los propietarios de sitios web especificar qué dominios pueden cargar sus recursos. Esto proporciona un control granular que ayuda a mitigar tanto los ataques XSS como los de clickjacking.⁴²

El Burp Proxy es la herramienta ideal para auditar estas configuraciones, permitiendo al analista inspeccionar las cabeceras de respuesta y verificar que estas defensas están implementadas correctamente.

5.2 Debilidades en el Cifrado

La implementación de HTTPS (HTTP sobre TLS) es una necesidad absoluta para proteger los datos en tránsito.²⁹ HTTPS cifra la comunicación entre el cliente y el servidor, protegiendo la información sensible como las credenciales de inicio de sesión y los datos enviados por el método POST de ser leídos en texto plano por un atacante en un ataque Man-in-the-Middle.⁴³

Sin embargo, la adopción de HTTPS no está exenta de desafíos. Puede introducir una ligera latencia o un mayor consumo de recursos del servidor debido al proceso de cifrado, aspectos que los desarrolladores deben gestionar para mantener el rendimiento.⁴⁴

Históricamente, los protocolos de cifrado han evolucionado en una carrera constante entre atacantes y defensores. TLS (Transport Layer Security) fue diseñado para corregir las vulnerabilidades inherentes de SSL (Secure Sockets Layer), que ahora está completamente obsoleto.⁴⁵ A continuación se presenta una tabla que resume las diferencias clave entre ambos protocolos.

Característica	SSL (Secure Sockets Layer)	TLS (Transport Layer Security)
Historial	Obsoleto. Versiones 1.0, 2.0 y 3.0. ⁴⁵	Versión mejorada de SSL. Versiones 1.0, 1.1, 1.2 y 1.3. Las versiones 1.2 y 1.3 están activas. ⁴⁵
Protocolo de Enlace	Proceso complejo y explícito, con más pasos. ⁴⁵	Proceso más rápido e implícito, con menos pasos. ⁴⁵
Autenticación	Utiliza el algoritmo MD5, que está obsoleto. ⁴⁵	Utiliza HMAC, para una criptografía más avanzada. ⁴⁵
Conjuntos de Cifrado	Admite algoritmos antiguos con vulnerabilidades conocidas. ⁴⁵	Utiliza algoritmos de cifrado avanzados. ⁴⁵
Mensajes de Alerta	No están cifrados y solo tiene dos tipos. ⁴⁵	Están cifrados y son más diversos. ⁴⁵

Los ataques históricos a estos protocolos son estudios de caso cruciales que demuestran la naturaleza evolutiva de la ciberseguridad.

- **Heartbleed:** En 2014, un error de programación en la popular biblioteca OpenSSL permitió a un atacante leer la memoria de un servidor, robando claves privadas y otros datos sensibles. Esto fue un fallo de implementación, no de diseño del protocolo, que resaltó la importancia de la calidad del código.⁴⁶
- **POODLE:** Este ataque forzó el uso del obsoleto SSL 3.0 para explotar una debilidad en su manejo del relleno de bloques de cifrado (CBC padding oracle), permitiendo descifrar el tráfico.⁴⁸
- **BEAST:** Un ataque Man-in-the-Middle que, al igual que POODLE, explotó debilidades en el encadenamiento de bloques de cifrado en la versión TLS 1.0 para descifrar tokens de autenticación.⁵⁰

Estos ataques del pasado no son solo eventos históricos, sino las fuerzas que impulsaron la creación de los protocolos de cifrado más seguros que utilizamos hoy, lo que refuerza que la seguridad es una carrera continua entre atacantes y defensores, y el conocimiento del pasado es vital para predecir las amenazas futuras.

6. Ataques sobre el Cliente y Sesiones de Usuario

6.1 Clickjacking (UI Redress Attack)

El clickjacking es una técnica de engaño basada en la interfaz que manipula al usuario para que haga clic en un enlace o botón invisible y malicioso.²⁹ La mecánica del ataque es ingeniosa: el atacante superpone una página web maliciosa, hecha transparente con CSS, sobre una página legítima.⁵³ Cuando el usuario interactúa con la página visible que cree que es legítima, en realidad está haciendo clic en la página oculta, lo que puede llevarlo a realizar acciones no deseadas, como descargar malware, revelar contraseñas o dar "me gusta" en una red social sin su conocimiento.²⁹

La principal defensa técnica contra esta vulnerabilidad es la implementación de las cabeceras X-Frame-Options y Content-Security-Policy (CSP).⁴² Estas cabeceras instruyen al navegador para que evite que una página sea incrustada en un iframe en otro dominio, eliminando el vector de ataque.²⁹ Un analista de seguridad puede utilizar el Burp Proxy para verificar la

presencia y correcta configuración de estas cabeceras.

6.2 CSRF (Cross-Site Request Forgery)

El Cross-Site Request Forgery (CSRF), o Falsificación de Solicitudes entre Sitios, es un ataque que obliga a un usuario a realizar una acción no deseada en una aplicación web en la que ya está autenticado.⁵⁴ Se diferencia del XSS en que se aprovecha de una sesión de usuario ya establecida para su explotación.⁵⁴

El mecanismo del ataque es el siguiente: un atacante engaña a la víctima (por ejemplo, a través de un correo electrónico con un enlace malicioso o un formulario oculto en un sitio web) para que, al visitar la página maliciosa, su navegador envíe una solicitud HTTP a una aplicación legítima (como su banco).⁵⁴ Debido a que la víctima ya ha iniciado sesión en la aplicación, su navegador envía automáticamente la cookie de sesión con la solicitud falsificada, y el servidor web la procesa como si fuera una acción legítima del usuario.⁵⁵ Esto podría llevar a una transferencia de fondos, un cambio de contraseña o cualquier otra acción que el atacante desee.⁵⁴

Tanto el clickjacking como el CSRF explotan un principio fundamental de confianza en el modelo del navegador: la suposición de que una acción del usuario es intencional. En CSRF, el servidor confía en la cookie de sesión sin un token que verifique la intención de la solicitud.⁵⁴ En clickjacking, el navegador ejecuta el clic sin verificar que el usuario está interactuando con la interfaz que cree que es.²⁹

La defensa más efectiva contra los ataques CSRF es la implementación de **tokens anti-CSRF**.⁵⁵ Estos son valores únicos y aleatorios que se generan en el servidor y se incluyen en el formulario de la página web. Cuando el usuario envía el formulario, el servidor verifica que el token recibido coincide con el token asociado a la sesión del usuario. Si no coinciden, la solicitud es rechazada, ya que no puede haber sido iniciada por el usuario de forma intencionada.⁵⁵

7. Conclusión y Próximos Pasos

El camino para convertirse en un analista de ciberseguridad es un proceso de aprendizaje continuo y práctico. Como hemos visto, una auditoría web exitosa requiere más que el simple uso de herramientas; demanda una comprensión profunda de las metodologías, las

vulnerabilidades y las interconexiones entre los diferentes componentes de la seguridad de una aplicación. El proceso de auditoría, desde la recopilación de información estratégica con un enfoque de bajo riesgo, pasando por el uso sinérgico de un proxy como Burp Suite, hasta la identificación de fallas lógicas y de inyección de código, es una disciplina que combina el conocimiento técnico con el pensamiento analítico.

Para el estudiante que está a punto de dar sus primeros pasos como analista, las siguientes recomendaciones son clave:

- **Priorice el conocimiento de la causa raíz:** Más allá de memorizar los payloads de ataque, es fundamental comprender por qué existe una vulnerabilidad. Comprender que IDOR y Directory Traversal son fallas en el control de acceso, o que los ataques de inyección se deben a una falta de validación de entrada, es lo que permite al analista pensar de forma estratégica y no solo reactiva.
- **Practique en entornos controlados:** Utilice laboratorios virtuales y plataformas de seguridad como OWASP Juice Shop o DVWA para probar las herramientas y técnicas descritas en este informe en un entorno seguro y legal.
- **Manténgase actualizado:** El panorama de amenazas evoluciona constantemente. El análisis de vulnerabilidades históricas como Heartbleed demuestra que el conocimiento del pasado es vital para anticipar los desafíos futuros, y el monitoreo de listas como el OWASP Top 10 es un hábito esencial.
- **Piense como un consultor:** Un analista de ciberseguridad no es solo un hacker ético. Es un profesional que ayuda a las organizaciones a construir sistemas más seguros desde el diseño, comunicando los riesgos de manera clara y proponiendo soluciones efectivas. La auditoría es el primer paso para fortalecer la defensa de un sistema, y la capacidad de comunicar sus hallazgos de forma convincente es la clave para generar un impacto real en la seguridad de una organización.

Obras citadas

1. ¿Qué es OWASP y cómo usar esta metodología? | Blog de Arsys ..., fecha de acceso: septiembre 23, 2025, <https://www.arsys.es/blog/owasp>
2. 5 Stages of Penetration Testing Explained | Step-by-Step Guide - Invicti, fecha de acceso: septiembre 23, 2025, <https://www.invicti.com/blog/web-security/5-stages-of-penetration-testing/>
3. Metodología OWASP (Open Web Application Security Project ..., fecha de acceso: septiembre 23, 2025, <https://book.h4ck.cl/metodologia-y-fases-de-hacking-etico/metodologias/metodologia-owasp-open-web-application-security-project>
4. Understanding the Five Phases of the Penetration Testing Process - EC-Council, fecha de acceso: septiembre 23, 2025, <https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/penetration-testing-phases/>
5. Understanding the Steps of Footprinting: A Guide for Penetration ..., fecha de acceso: septiembre 23, 2025,

- <https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/footprinting-steps-penetration-testing/>
6. Insecure Direct Object Reference (IDOR): qué es y cómo funciona - YouTube, fecha de acceso: septiembre 23, 2025, https://www.youtube.com/watch?v=jvDFilyNW_o
 7. ¿Qué es OWASP? OWASP Top 10 de vulnerabilidades y riesgos - F5, fecha de acceso: septiembre 23, 2025, https://www.f5.com/es_es/glossary/owasp
 8. Footprinting - Wikipedia, fecha de acceso: septiembre 23, 2025, <https://en.wikipedia.org/wiki/Footprinting>
 9. ESCANEO PASIVO : APRENDE A RECOPIRAR INFORMACIÓN PÚBLICA  CON ESTAS HERRAMIENTAS DE HACKING ÉTICO. - YouTube, fecha de acceso: septiembre 23, 2025, <https://www.youtube.com/watch?v=tkPtmhgONmg>
 10. Curso de Hacking Ético Nivel 1 - Recolección de información pasiva - YouTube, fecha de acceso: septiembre 23, 2025, <https://www.youtube.com/watch?v=eYEAeySelf>
 11. 10 herramientas de OSINT que todo Hacker debe saber usar ..., fecha de acceso: septiembre 23, 2025, <https://achirou.com/10-herramientas-de-osint-que-todo-hacker-debe-saber-usar/>
 12. 10 herramientas OSINT que todo hacker ético debe conocer - Q2BStudio, fecha de acceso: septiembre 23, 2025, <https://www.q2bstudio.com/nuestro-blog/25969/10-herramientas-osint-que-todo-hacker-etico-debe-conocer>
 13. www.fortinet.com, fecha de acceso: septiembre 23, 2025, <https://www.fortinet.com/lat/resources/cyberglossary/proxy-server#:~:text=Los%20servidores%20proxy%20proporcionan%20una,amenazas%20de%20Internet%20como%20malware.>
 14. ¿Qué es un proxy y para qué sirve? | Blog de Arsys, fecha de acceso: septiembre 23, 2025, <https://www.arsys.es/blog/que-es-un-proxy-y-para-que-sirve>
 15. Burp Suite: o que é e como funciona? - Solyd Blog, fecha de acceso: septiembre 23, 2025, <https://blog.solyd.com.br/o-que-e-o-burp-suite/>
 16. Features - Burp Suite Professional - PortSwigger, fecha de acceso: septiembre 23, 2025, <https://portswigger.net/burp/pro/features>
 17. Burp Suite Encoder & Decoder Tutorial - Hacking Articles, fecha de acceso: septiembre 23, 2025, <https://www.hackingarticles.in/burpsuite-encoder-decoder-tutorial/>
 18. Cómo instalar y configurar FoxyProxy para usar Burp Suite en Kali Linux | 2023 - YouTube, fecha de acceso: septiembre 23, 2025, <https://www.youtube.com/watch?v=wY0EBp2OeHo>
 19. How to configure Burp Suite with Firefox FoxyProxy on Kali Linux - YouTube, fecha de acceso: septiembre 23, 2025, <https://www.youtube.com/watch?v=MyJnuw7afX8>
 20. Pruebas de Seguridad Web con Burp Suite y Kali Linux | LabEx, fecha de acceso: septiembre 23, 2025, <https://labex.io/es/tutorials/kali-kali-web-testing-with-burp-suite-552302>

21. Getting started with Burp Suite Professional / Community Edition - PortSwigger, fecha de acceso: septiembre 23, 2025, <https://portswigger.net/burp/documentation/desktop/getting-started>
22. Reissuing requests with Burp Repeater - PortSwigger, fecha de acceso: septiembre 23, 2025, <https://portswigger.net/burp/documentation/desktop/getting-started/reissuing-http-requests>
23. Typical uses for Burp Intruder - PortSwigger, fecha de acceso: septiembre 23, 2025, <https://portswigger.net/burp/documentation/desktop/tools/intruder/uses>
24. Burp Intruder attack types - PortSwigger, fecha de acceso: septiembre 23, 2025, <https://portswigger.net/burp/documentation/desktop/tools/intruder/configure-attack/attack-types>
25. BurpSuite Decoder Unwrap For Pentesters (PART-7), fecha de acceso: septiembre 23, 2025, <https://blog.certcube.com/burpsuite-decoder-unwrap-for-pentesters/>
26. Vulnerabilidad IDOR (referencias directas a objetos ... - Wallarm, fecha de acceso: septiembre 23, 2025, <https://lab.wallarm.com/what/vulnerabilidad-idor-referencias-directas-a-objetos-inseguras/?lang=es>
27. What is directory traversal? - Fastly, fecha de acceso: septiembre 23, 2025, <https://www.fastly.com/learning/application-attacks/what-is-directory-traversal>
28. Directory Traversal: Vulnerability and Prevention | Veracode, fecha de acceso: septiembre 23, 2025, <https://www.veracode.com/security/directory-traversal/>
29. Seguridad de Sitios Web - Aprende desarrollo web | MDN - Mozilla, fecha de acceso: septiembre 23, 2025, https://developer.mozilla.org/es/docs/Learn_web_development/Extensions/Server-side/First_steps/Website_security
30. Ataques de validación de entrada - Wikipedia, la enciclopedia libre, fecha de acceso: septiembre 23, 2025, https://es.wikipedia.org/wiki/Ataques_de_validaci%C3%B3n_de_entrada
31. Cómo implementar la validación y el saneamiento de entrada en Ciberseguridad - LabEx, fecha de acceso: septiembre 23, 2025, <https://labex.io/es/tutorials/wireshark-how-to-implement-input-validation-and-sanitization-in-cybersecurity-417883>
32. SQL injection - Wikipedia, fecha de acceso: septiembre 23, 2025, https://en.wikipedia.org/wiki/SQL_injection
33. What is SQL Injection? Tutorial & Examples | Web Security Academy, fecha de acceso: septiembre 23, 2025, <https://portswigger.net/web-security/sql-injection>
34. Testing for reflected XSS manually with Burp Suite - YouTube, fecha de acceso: septiembre 23, 2025, <https://www.youtube.com/watch?v=ecuiE83zvqY>
35. What Is Command Injection? | Examples, Methods & Prevention ..., fecha de acceso: septiembre 23, 2025, <https://www.imperva.com/learn/application-security/command-injection/>
36. Code Injection - OWASP Foundation, fecha de acceso: septiembre 23, 2025, https://owasp.org/www-community/attacks/Code_Injection
37. RFI - LFI - Radware, fecha de acceso: septiembre 23, 2025,

- <https://www.radware.com/security/ddos-knowledge-center/ddospedia/rfi-lfi/>
38. File Inclusion Attacks – Understanding LFI and RFI Exploits - Indusface, fecha de acceso: septiembre 23, 2025, <https://www.indusface.com/learning/file-inclusion-attacks-lfi-rfi/>
39. ¿Qué es un ataque de fuerza bruta? Definición, tipos y cómo funciona | Fortinet, fecha de acceso: septiembre 23, 2025, <https://www.fortinet.com/lat/resources/cyberglossary/brute-force-attack>
40. ¿Qué es un ataque de fuerza bruta? - Akamai, fecha de acceso: septiembre 23, 2025, <https://www.akamai.com/es/glossary/what-is-brute-force-attack>
41. HTTP headers - MDN - Mozilla, fecha de acceso: septiembre 23, 2025, <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers>
42. HTTP Headers - OWASP Cheat Sheet Series, fecha de acceso: septiembre 23, 2025, <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>
43. Why is HTTP not secure? The difference between HTTP and HTTPS - Gcore, fecha de acceso: septiembre 23, 2025, <https://gcore.com/learning/http-vs-https-security-comparison>
44. The Pros And Cons Of Implementing SSL / HTTPS - Nexcess, fecha de acceso: septiembre 23, 2025, <https://www.nexcess.net/blog/the-pros-and-cons-of-implementing-ssl-https/>
45. SSL y TLS: diferencia entre los protocolos de comunicación. AWS, fecha de acceso: septiembre 23, 2025, <https://aws.amazon.com/es/compare/the-difference-between-ssl-and-tls/>
46. Heartbleed - Asperis Security, fecha de acceso: septiembre 23, 2025, <https://www.asperis.es/glosario-ciberseguridad/heartbleed/>
47. Preventing Heartbleed Vulnerabilities - Veracode, fecha de acceso: septiembre 23, 2025, <https://www.veracode.com/security/heartbleed-vulnerabilities>
48. O que é um ataque POODLE e como ele funciona? - SSL Dragon, fecha de acceso: septiembre 23, 2025, <https://www.ssldragon.com/pt/blog/what-is-poodle-attack-ssl/>
49. ¿Qué es el ataque POODLE? (CVE-2014-3566) Explicado - Wallarm, fecha de acceso: septiembre 23, 2025, <https://lab.wallarm.com/what/ataque-de-poodle/?lang=es>
50. Prevent SSL BEAST attacks - Veracode Docs, fecha de acceso: septiembre 23, 2025, <https://docs.veracode.com/r/prevent-ssl-beast>
51. What is a BEAST Attack? Vulnerability of TLS/SSL protocols - Wallarm, fecha de acceso: septiembre 23, 2025, <https://www.wallarm.com/what/what-is-a-beast-attack>
52. developer.mozilla.org, fecha de acceso: septiembre 23, 2025, <https://developer.mozilla.org/es/docs/Web/Security/Attacks/Clickjacking#:~:text=Clickjacking%20es%20un%20ataque%20basado,hagan%20clic%20en%20enlaces%20maliciosos.>
53. ¿Qué es el clickjacking? - Friendly Captcha, fecha de acceso: septiembre 23, 2025, <https://friendlycaptcha.com/es/wiki/what-is-clickjacking/>

54. ¿Qué es CSRF (Falsificación de solicitudes entre sitios)? | Fortinet, fecha de acceso: septiembre 23, 2025,
<https://www.fortinet.com/lat/resources/cyberglossary/csrf>
55. Prevención de ataques de falsificación de solicitudes entre sitios (CSRF) en ASP.NET MVC, fecha de acceso: septiembre 23, 2025,
<https://learn.microsoft.com/es-es/aspnet/web-api/overview/security/preventing-cross-site-request-forgery-csrf-attacks>